

Artificial Intelligence Risk Management Framework (AI RMF 1.0) (National Institute for Standards and Technology, 2023)

Reading Notes

risk management can help all of us consider more carefully the risks and benefits of AI use

overall goal: help increase trustworthiness of AI systems and foster responsible design, development, deployment, and use of AI systems

four key functions to manage risks and develop trustworthy systems: Govern, Map, Measure, Manage

risk management should take place continuously and “throughout AI lifecycle dimensions”

general flow would be to move from Govern → Map → Measure → Manage

if your organization isn’t highly resources, consider prioritizing the most important subcategories of each area

Govern

primary objective: build a culture and set of processes in which context-appropriate risk management can take place (in their words, “a purpose-driven culture focused on risk understanding and management,” which is a bit different from my synthesis from an earlier part of the section)

enables the other elements of their framework (Map, Measure, Manage)

important to consider the individual organization’s mission, goals, values, culture, and risk tolerance

categories of governance related to mapping, measure, and managing AI risks:

1. effective & transparent implementation of policies, processes, procedures, and practices
 - a. legal & regulatory requirements
 - b. trustworthy AI integrated throughout
 - c. risk management calibrated to organization’s risk tolerance
 - d. transparent development & implementation
 - e. regular monitoring & review (including who’s responsible)

- f. regular inventorying of AI systems (requires appropriate resources)
 - g. processes & procedures for sunseting use of AI systems safely and trustworthily
- 2. accountability structures for empowerment, responsibility, and training (for teams and/or individuals)
 - a. clear roles, responsibilities, and lines of communication
 - b. appropriate training
 - c. leadership takes responsibility for decisions about risks
- 3. DEI & accessibility practices prioritized throughout the lifecycle
 - a. all decision-making informed by diverse teams
 - b. clear methods for defining & differentiating roles and responsibilities for oversight of AI systems and human-AI configurations
- 4. development of a culture which considers & communicates AI risk
 - a. culture values/fosters critical thinking and a safety-first mindset when considering new AI systems
 - b. risks & potential impacts of AI technology (designed, developed, deployed, evaluated, used) documented & discussed
 - c. practices support AI testing, incident identification, and information sharing
- 5. robust engagement with relevant extra-organizational AI actors
 - a. implementation of policies & practices for getting (and acting on, if appropriate) feedback from external actors and/or AI system developers
 - b. (seems rather like A)
- 6. implementation of policies & procedures related to third-party software, data, and supply chain issues
 - a. consideration of third-party issues (e.g., intellectual property rights)
 - b. contingency processes for handling failures/incidence related to third-party data or high-risk AI systems

Map

helps to frame AI-related risks (anticipate, assess, address)

Map outcomes are foundational for Measure and Manage functions

important to incorporate diverse perspectives, including those external to the organization, end users, (potentially) impacted communities, etc.

once Map is completed, you should be able to make a decision: go forward or don't go forward

categories:

1. context established & understood
 - a. documentation (including understanding) of intended purposes, beneficial uses, context-specific laws, norms and expectations, & prospective settings
 - b. diversity established for context discussions & participation documented
 - c. documentation of organizational mission & relevant goals for AI technology
 - d. clear definition of business use/context of business use (evaluation or re-evaluation for existing tools)
 - e. determination & documentation of organizational risk tolerance
 - f. elicitation of system requirements which take socio-technical implications into account
2. AI systems categorized
 - a. definition of specific tasks and methods for AI systems
 - b. documentation of the (knowledge) limits of AI systems
 - c. research & scientific integrity concerns discussed & documented
3. AI system capabilities, targeted usage, goals, expected benefits, and expected costs understood & compared to benchmarks
 - a. examination & documentation of potential AI system functionality and performance
 - b. examination & documentation of potential costs, including non-monetary
 - c. documentation of targeted application scope (capability, context, categorization)
 - d. definition, assessment & documentation of operator & practitioner proficiency so that they can perform in a trustworthy manner
 - e. definition, assessment, and documentation of human oversight, aligned with principles established in Govern)
4. risk-benefit mapping
 - a. approaches to mapping AI technology & legal risks are in place (???)
 - b. identification and documentation of internal risk controls (?) for AI systems (including third-party tools)
5. outline of impacts to individuals, groups, communities, organization, and society
 - a. identification & documentation of likelihood & magnitude of identified impacts (positive & negative) based on expected use, past uses of similar tools, public incidents, and feedback
 - b. documentation of methods (practices & people) to support engagement & integrating feedback

Measure

purpose: analyze, assess, benchmark, & monitor AI risks & impacts

informed by Map, informs Manage

is pretty research-y - intended to be scientific explorations of risks & impacts

categories & subcategories:

1. identification & application of appropriate methods and metrics
 - a. selection & documentation of approaches & metrics for measuring risks & trustworthiness characteristics (including those cannot/will not be measured)
 - b. assessment & updating of appropriateness of metrics (including error reports and community impacts)
 - c. independent assessment & updates by internal experts not closely involved + consultation of others (domain experts, users, community members, etc.)
2. evaluation of AI systems for trustworthiness
 - a. documentation of test sets, metrics, and details
 - b. compliance with appropriate policies for research involving human subjects
 - c. documentation of measurements of system performance/assurance criteria in conditions similar to deployment setting(s)
 - d. monitoring of functionality & behavior of AI system and components
 - e. documentation of determinations that the AI system is valid & reliable + limits of generalizability
 - f. regular evaluation for safety risks
 - g. evaluation and documentation of AI system security & resilience
 - h. examination & documentation of transparency & accountability risks
 - i. explanation, validation, & documentation available to inform responsible use & governance
 - j. examination & documentation of privacy risks
 - k. evaluation & documentation of fairness and bias risks
 - l. evaluation & documentation of environmental impact & sustainability, including model training
 - m. evaluation & documentation of employed metrics & processes
3. implementation of mechanisms for tracking identified risks over time
 - a. implementation of approaches, personnel, and documentation to identify & track risks (existing, unanticipated, emergent)
 - b. consideration of risk tracking approaches for settings in which risks are difficult to assess or where existing metrics don't work
 - c. establishment & integration of feedback processes for end uses and impacted communities to report problems and appeal system outcomes

4. gathering & assessment of feedback on efficacy of measurements
 - a. connection of measurement approaches to deployment contexts & informed by experts & end uses
 - b. integration of input from experts & other relevant actors on the measurement results
 - c. identification of measurable performance improvements/declines from stakeholders

Manage

“allocation of risk resources to mapped and measured risks”

once completed, you’ll have plans for prioritizing risk and systems for monitoring and improvement

categories & subcategories:

1. prioritization, response to, and management of AI risks based on assessments from Map and Measure
 - a. decision on whether to proceed with the AI system
 - b. prioritization of how documented AI risks will be handled
 - c. development, planning & documentation of responses to high priority risks (mitigation, transfer, avoidance, acceptance)
 - d. documentation of risks to downstream acquirers & end users
2. planning, preparation, implementation, and documentation of strategies to maximize benefits & minimize drawbacks
 - a. accounting for resources needed to manage AI risks (and considering non-AI alternatives)
 - b. implementation and application of systems for sustaining value of deployed systems
 - c. following procedures to respond to & recover from previously unknown risk(s)
 - d. implementation & application of procedures for deciding if/when a system needs to be superseded, disengaged from, or deactivated
3. management of risks and benefits from third-party entities
 - a. monitoring of risks and benefits from third-party resources + application and documentation of risk controls
 - b. monitoring & maintenance of pre-trained models for development
4. documentation & monitoring of how risks & negative incidents are handled
 - a. implementation of post-deployment AI system monitoring plans
 - b. integration of measurable activities for continuous improvement

- c. communication of incidents & errors + documentation of process for tracking, responding, & recovering

Reading Questions

1. The NIST AI RMF organizes risk management into four functions: GOVERN, MAP, MEASURE, MANAGE. What does each function cover, and what happens in an organization that has only implemented GOVERN (written policies) without MAP or MEASURE?

The Govern function covers establishing a culture and processes in which context-appropriate risk management can take place. The Map function frames AI-related risks. The Measure function serves to provide quantitative and qualitative exploration and documentation of those risks. The Manage function serves to allocate resources to dealing with risks based on work done in the Map and Manage phases. If an organization only implemented Govern, they would have articulate aspirations but not implemented any kind of action plan.

2. NIST lists seven trustworthiness properties for AI systems. Which three are most relevant to AI used in student-facing services at a university, and why?

This was not covered in the portion of the reading we were assigned, but I think the three most important properties are: (1) safe, (2) privacy-enhanced, and (3) secure and resilient. In all three cases, this is because if we cannot be reasonably sure that the system will not cause harm, it should not be used in the first place. This principle applies to personal safety, health, and privacy, as well as other domains.

3. The NIST framework is 'voluntary' in the U.S. context — there is no current federal law requiring its adoption. What incentive structures (accreditation, grant requirements, litigation risk) might effectively make it de facto mandatory for research universities?

I don't think anything would make *this specific framework* de facto mandatory for research universities. However, universities do tend to be very risk averse and are exposed to many different legal risks, so I would expect that they would need to apply some kind of system or other, but whether it's this framework or some other framework remains to be seen. I would anticipate that at most universities, the approach would be much more disparate and cobbled-together rather than unified because universities are highly decentralized and it's quite difficult to achieve central coordination on anything when you have so many disparate units and levels of management.

4. How does the NIST AI RMF's definition of 'AI risk' compare to the way your institution currently discusses AI risk in its communications or policies? What risk categories does your institution address? What does it miss?

U of A seems to be mostly concerned with specific uses of AI (i.e., in research, in the classroom) and less with conceptualizing AI and AI risk more broadly. Not much seems to exist except for either references to pre-existing policies or references to specific applications (AI in syllabi, AI and academic honesty, AI in research). They don't really address staff use of AI at all, and the existing set of resources and website mostly makes it feel like there's no coordinated approach or position.

Key Terms

Term	My Definition
AI RMF Core functions (GOVERN, MAP, MEASURE, MANAGE)	• Govern: establishes a culture and processes in which context-appropriate risk management can take place • Map: frames AI-related risks • Measure: provides quantitative and qualitative exploration and documentation of those risks • Manage: allocates resources to dealing with risks based on work done in the Map and Manage phases
AI trustworthiness properties	• safe: does not endanger life, health, property, or the environment • secure & resilient: can handle unexpected negative events or sudden environmental changes • explainable & interpretable: underlying mechanisms can be described & outputs make sense and are useful • privacy-enhanced: does not endanger autonomy, identity, or dignity • fair - with harmful bias managed: does not promote bias or discrimination • valid & reliable: predictably fulfill their intended role • accountable & transparent: information about the system is available to users and developers are responsible both for the benefits and the shortcomings
AI actor	individual people and organizations who use AI

Risk management	the process of navigating the potential for adverse events as a result of a decision, technology, etc. - can be individual or organizational
Principles-based governance	not used as a term in the reading, but using organizational values to guide decision-making on challenging topics

UNESCO recommendations on the ethics of artificial intelligence - Executive Summary (UNESCO, 2021)

Reading Notes

Values

1. respect, protection, and promotion of human rights and fundamental freedoms and human dignity
 - a. all systems should respect human dignity (the “intrinsic and equal worth of each individual human being”)
 - b. no system should harm or subordinate anyone, and systems should serve to enhance quality of life
 - c. systems should not objectify people
 - d. systems should protect human rights and fundamental freedoms
2. environment and ecosystem flourishing
 - a. AI systems should recognize, protect, and promote environmental and ecosystem flourishing
 - b. AI systems should comply with local regulations & standards as well as work to reduce their environmental impact
3. ensuring diversity and inclusiveness
 - a. systems should respect, protect, and promote D&I, which requires active participation of diverse groups
 - b. using an AI system should not require anyone to compromise their lifestyle choices, beliefs, opinions, expressions, or personal opinions
 - c. there need to be international efforts to overcome the lack of technical infrastructure in less developed areas
4. living in peaceful, just, and interconnected societies
 - a. AI actors should promote peaceful and just societies
 - b. (doesn't say anything additional)

- c. AI systems should promote peace, inclusiveness, justice, equity, and interconnectedness

Principles

1. proportionality and do no harm
 - a. AI systems should only go as far as needed to achieve objectives and should not harm people
 - b. decisions on use of AI systems should be informed by:
 - i. appropriateness and proportionality to achieve stated aims
 - ii. not infringing on the foundational values put forth in this document
 - iii. appropriateness for context and based on rigorous research
 - iv. (also, if decisions are irreversible, they need to be made by a human)
2. safety and security
 - a. systems should not pose safety risks and should not contain vulnerabilities
3. fairness and non-discrimination
 - a. AI actors should promote social justice & protect fairness and non-discrimination, which requires input from diverse sources, which includes localization (language, culture) and wealthier nations making sure access is universal
 - b. AI actors and systems should not reinforce or perpetuate discrimination and allow for effective remedy should those problems arise
 - c. digital and knowledge divides need to be addressed
4. sustainability
 - a. AI development should proceed with an eye toward sustainability
5. right to privacy and data protection
 - a. AI systems must respect, protect, and promote privacy
 - b. there need to be good data protection frameworks and governance mechanisms, arrived at by a multi-stakeholder process
 - c. there need to be privacy impact assessments
6. human oversight and determination
 - a. ethical and legal responsibility must always be attributable so that remedy can be made as needed
 - b. AI systems should never replace ultimate human responsibility and accountability
7. transparency and explainability
 - a. both transparency and explainability are necessary preconditions for other elements on this list

- b. people have a right to know when an algorithm is making a decision about them
 - c. (just additional explanation about what transparency is)
 - d. (just a definition of explainability)
 - e. (more on why they're important)
- 8. responsibility and accountability
 - a. AI actors need to accept responsibility for respecting, protecting, and promoting human rights and fundamental freedoms as well as promoting environmental/ecosystem protection, and that responsibility needs to be attributable to someone
 - b. strong oversight, impact assessment, audit, and due diligence processes should be established
- 9. awareness and literacy
 - a. there needs to be greater public awareness and understanding of AI technologies and the value of data
 - b. learning about AI should include learning about human rights and fundamental freedoms
- 10. multi-stakeholder and adaptive governance and collaboration
 - a. data use must respect international law and national sovereignty
 - b. there needs to be a diverse set of stakeholders to achieve effective AI governance

Reading Questions

1. The UNESCO Recommendation is legally non-binding but was adopted unanimously by 193 member states. What does this status imply for its authority relative to the EU AI Act (legally binding) and the NIST AI RMF (voluntary U.S. framework)?

This makes it more similar to the NIST AI RMF since it not legally binding. It may be useful for people or organizations to consider, but there's no requirement for them to do so.

2. UNESCO grounds its framework in human rights law rather than technical risk management. How does this rights-based framing change the governance questions a university would need to ask before deploying an AI system in student advising?

This is a people-first rather than technology-first framing. As such, it requires putting the emphasis on the "socio" portion of "socio-technical." It would require a

university to consider community and societal impacts more strongly than a mere technical focus.

3. Compare UNESCO's list of core values with NIST's trustworthiness properties. What does UNESCO address that NIST does not? What does NIST address that UNESCO treats only implicitly?

UNESCO addresses human dignity and human rights and also foregrounds the environment and diversity and inclusion in a way that NIST only references in passing. The only element from the NIST properties that UNESCO doesn't address directly is security and resilience.

4. UNESCO calls for 'meaningful human oversight' of AI systems as a core principle. What does 'meaningful' oversight require in a university context — what mechanisms would make oversight more than a formality?

I think “meaningful” means that the processes are designed by humans and that humans are able to make key decisions. Designing explicit check-in points would be one way to make this an active process rather than a passive one.

Key Terms

Term	My Definition
Multi-stakeholder governance	the term isn't used in the reading, but it refers to situations in which key decisions are made by a diverse set of people representing different interests
Human rights-based AI governance	the term isn't used in the reading, but this is the approach UNESCO takes, which grounds guidance and principles for AI use in the fundamental freedoms and dignity for people that it espouses
Right to privacy (UNESCO framing)	they don't explicitly define privacy, but their definition seems to be that people have the right to determine how their data and content they create is used, including for it to not be used
Meaningful human oversight	the term isn't used in the reading, but this refers to humans determining and controlling all important decision points in which AI is utilized
Equity in AI benefit distribution	the term isn't used in the reading, but throughout the values and principles, UNESCO is insistent that the benefits of AI should flow to all and not just to the wealthiest people or countries